

Phishing Email Detection & Awareness Report

Cyber Security Internship — Future Interns

Intern: Lalas Maruthi | CIN ID: FIT/AUG26/CS10164

Sample source: publicly available phishing-email datasets

Date: 27-08-2026

1. What this task was about

For this task I pulled a small set of sample emails — some phishing, some legitimate — and went through them the way a security analyst actually would: checking the sender, the headers, where the links really point, and the tone of the message. The goal wasn't just to label them, but to be able to explain to someone non-technical exactly why each one is or isn't safe.

2. How I went through each one

- Checked the sender's actual address against the display name — these often don't match
- Looked at header authentication results (SPF/DKIM/DMARC) where available
- Hovered over/inspected every link to see the real destination, not just the display text
- Noticed the tone — urgency, threats, or unusual requests are a strong signal on their own
- Checked any attachments for suspicious file types or naming

3. What I classified each one as

ID	Subject Line	Classification	Why
E-01	"Your account will be suspended in 24 hours"	Phishing	Urgency + spoofed domain
E-02	"Invoice #40217 attached — payment overdue"	Phishing	Malicious attachment naming
E-03	"IT: password reset required"	Phishing	Credential-harvesting link
E-04	"Quarterly newsletter sign-up confirmation"	Suspicious	Look-alike domain, low confidence
E-05	"Meeting notes from today"	Safe	Known sender, clean headers, no links

4. Walking through the interesting ones

E-01 — the fake account suspension notice

This one was the most textbook example. The sending domain looked right at a glance but wasn't — a character was swapped. The message pushes urgency ("24 hours") specifically so you don't stop and check anything, and while the button text shows a real-looking URL, the actual link underneath goes somewhere completely different.

What I'd tell a user: don't click, report it through the proper channel, and delete it.

E-02 — the fake invoice

The attachment here isn't actually a PDF — it's a compressed file with an executable inside it, just named to look like an invoice. There's also no name used anywhere in the email, just "Dear Customer," which real vendors almost never do.

What I'd tell a user: never open an unexpected attachment — call the vendor directly using a number you already know, not one from the email.

E-03 — the fake password reset

This one's sneakier. The link text shows the real company portal address, but hovering over it reveals a different destination entirely. It also asks for your current password, which a legitimate IT reset process would never do by email.

What I'd tell a user: go to the password portal by typing the URL yourself — never through a link in an email.

E-04 — the newsletter confirmation (flagged, not confirmed)

I want to be upfront that I wasn't fully confident calling this phishing outright — the domain is close to the real one but off by a single character, and there's no urgent request or payload. I flagged it as suspicious rather than confirmed, which felt like the more honest call.

E-05 — the internal meeting notes (safe baseline)

Included this one on purpose as a comparison point — matches a known internal sender, passes SPF/DKIM/DMARC, no links or attachments. Useful to have a "this is what normal looks like" example next to the bad ones.

5. Guidelines I'd actually give end users

- Check the sender's real address, not just the name shown
- Hover over links before clicking — look at where they actually go
- Treat urgency and threats as a reason to slow down, not speed up
- Never enter a password or MFA code through a link in an email
- Verify unexpected invoices or payment requests through a separate channel you already trust
- Report suspicious emails properly instead of just deleting them — it helps everyone else too

6. What this task taught me

The thing that surprised me most is how little actual technical sophistication most phishing emails need — E-01 through E-03 all relied on a person being rushed or not looking closely, not on some clever exploit. That changed how I think about awareness training: it's less about teaching people to spot code and more about teaching them to just slow down for ten seconds.